

บทที่ 6

เครื่องมือช่วยเหลือ

เครื่องมือช่วยเหลือในการค้นหาช่องโหว่ของเว็บแอปพลิเคชัน ซึ่งมีประโยชน์มากสำหรับ Web Programmers ต่างๆ ที่ต้องการความปลอดภัยเกี่ยวกับเว็บที่ตนเองเขียนขึ้น ซึ่งเครื่องมือเหล่านี้มีอยู่มากมายแต่จะกล่าวเฉพาะเครื่องมือที่ได้รับความนิยมเท่านั้น

6.1 Netcat

Netcat ทำหน้าที่เป็นเสมือนผู้ส่งภาษา HTTP แบบดิบ ร้องขอข้อมูลจากเว็บเซิร์ฟเวอร์โดยไม่ต้องมีไโอเวอร์เฮดเหมือนกับเว็บเซอร์เวอร์ทั่วไป จริงๆ แล้วในหลายๆ กรณี Netcat สามารถแทนที่บราวเซอร์ได้อย่างสมบูรณ์สำหรับการแสดเว็บ กล่าวได้อีกอย่างหนึ่งคือ Netcat สามารถทำได้แทบจะทุกอย่าง และเพราะว่ามันเป็นเครื่องมือแบบบรรทัดคำสั่ง มันจึงสามารถนำมาเขียนสคริปต์สั่งงานอัตโนมัติได้

ตัวอย่างการใช้ Netcat เพื่อดึงเอาดีฟอลต์เว็บเพจมาจากเซิร์ฟเวอร์ดังรูปที่ 6.1

```
C:\> nc 192.168.0.5 81
GET / HTTP/1.0<cr><lf>
<cr><lf>
HTTP/1.1 200 OK
Server: Microsoft-IIS/5.0
Content-Location: http://192.168.0.5/Default.htm
Date: Sat, 27 Apr 2002 18:00:28 GMT
Content-Type: text/html
Accept-Ranges: bytes
Last-Modified: Sat, 06 Apr 2002 06:48:32 GMT
ETag: "a0f7751137ddc11:8fa"
Content-Length: 5

Hello
```

รูปที่ 6.1 การใช้ Netcat

ตัวอย่างข้างต้น เท็กซ์ที่เป็นตัวหนาจะถูกพิมพ์ลงไปในการบรรทัดคำสั่งหลังจาก Netcat เริ่มต้นรันสังเกตว่า <cr><lf> เป็นการใส่แทนการเคาะคีย์ Enter ที่ตอนท้ายของแต่ละบรรทัดซึ่งจะต้องถูกเคาะสองครั้งในตอนท้ายของแต่ละบรรทัดก่อนที่คำสั่งจะถูกส่งไปยังเว็บเซิร์ฟเวอร์ แล้วใส่คำว่า

“Hello” ลงไปบรรทัดเดียวที่เพจ default.asp บนเซิร์ฟเวอร์ ดังนั้นจึงได้รับตอบกลับจากเว็บเซิร์ฟเวอร์ก็คือ ส่วนของเฮดเดอร์ของ HTTP/1.1 และคำว่า “Hello”

6.2 Whisker

Whisker ซึ่งเป็นหนึ่งในเครื่องมือแรกที่แข็งแกร่งและสามารถตรวจหาช่องโหว่บนเว็บได้อย่างมีประสิทธิภาพได้รับการยอมรับว่ามีความฉลาดและอัลกอริทึมที่ดีเป็นเวลากว่าหลายปีมาแล้ว และปัจจุบันก็ยังคงเป็นเช่นนั้นอยู่ เครื่องมือนี้ประกอบด้วยลิสต์รายการช่องโหว่บนเว็บต่างๆที่ได้รับการค้นพบจากอดีตจนถึงปัจจุบันซึ่งแหล่งข้อมูลเกี่ยวกับช่องโหว่นั้นทาง RFP ได้รวบรวมมาจากแหล่ง อาทิ Nomad Mobile Research Center (NMRC), World Wide Web Consortium (W3C), Fyodor's Insecure.org, Rootshell.com, Bugtraq, cgichk.c, Network Associates' CyberCop, Packetstorm, ucgi.c และอื่นๆอีกมาก ทำให้มันเป็นเครื่องมือที่ค่อนข้างสมบูรณ์ทีเดียว

Whisker ทำงานได้บนแพลตฟอร์มวินโดวส์และยูนิกซ์ ทำให้มันได้รับความนิยมและถูกใช้งานอย่างกว้างขวาง Whisker ทำงานโดยการพยายามคอนเน็กไปยังเว็บเซิร์ฟเวอร์เป้าหมายพร้อมทั้งตรวจเช็คช่องโหว่โดยอาศัยฐานข้อมูลจากไฟล์ scan.db ไฟล์นี้เป็นตัวกำหนดว่าจะตรวจเช็คช่องโหว่ที่จุดไหนบ้าง ถ้ามันสามารถคอนเน็กไปยังเซิร์ฟเวอร์ได้สำเร็จและได้รับเอาต์พุตจากเซิร์ฟเวอร์กลับมาในฟอร์มเมตที่มันคาดไว้ Whisker จะบอกว่าเซิร์ฟเวอร์มีช่องโหว่นั้นๆ ถึงแม้ว่าเอ็นจินของมันจะไม่ฉลาดที่สุด และอาจส่ง False Positive กลับมา (หมายถึง เซิร์ฟเวอร์ไม่มีช่องโหว่ แต่บอกว่ามีช่องโหว่)

ตัวอย่างโปรแกรมดังรูปที่ 6.2

```
C:\nt\whisker\v1.4>whisker.pl -h 192.168.0.5
-- whisker / v1.4.0 / rain forest puppy / www.wiretrip.net -- = -
= Host: 192.168.0.5
= Server: Apache/1.3.12 (Win32) ApacheJServ/1.1
mod_ssl/2.6.4 OpenSSL/0.9.5a mod_perl/1.22

+ 200 OK: HEAD /cgi-bin/printenv
+ 200 OK: HEAD /manual/
```

รูปที่ 6.2 โปรแกรม Whisker

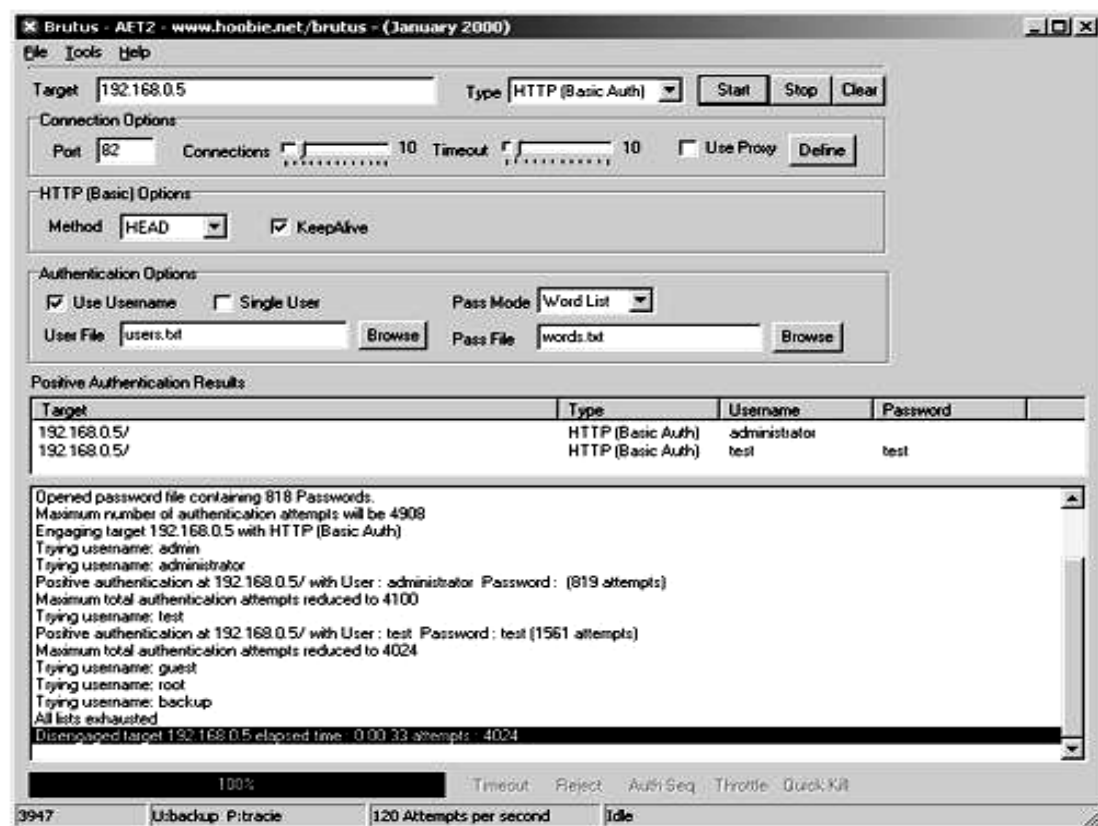
จากรูปที่ 6.2 Whisker คอนเน็กไปยังเว็บเซิร์ฟเวอร์บนพอร์ต 80 บนเครื่อง 192.168.0.5 และทราบว่าเซิร์ฟเวอร์นี้รัน Apache/1.3.12 for Windows (Win32) มันสามารถบอกได้ว่ามีอยู่ที่โปรแกรมที่ทำงานอยู่บนเว็บเซิร์ฟเวอร์ได้แก่ ApacheJServ/1.1, mod_ssl/2.6.4, OpenSSL/0.95a และ mod_perl/1.22 และยังพบอีกว่ามีอยู่สองลิงก์ที่มีโอกาสถูกใช้เป็นเส้นทางเข้าโจมตีเซิร์ฟเวอร์ได้ คือ /cgi-bin/ และ printenv อีกด้วย จากนั้น Whisker ยังสามารถทำ Brute Force เพื่อเดารหัสผ่านอีกด้วย

6.3 Brutus

เป็นเครื่องมือแครกเกอร์รหัสผ่านบนเว็บที่มีฟีเจอร์หลากหลาย โปรแกรมนี้ได้รับการพัฒนาให้ทำงานเฉพาะบนวินโดวส์เท่านั้นและเปิดโอกาสให้ใช้เทคนิคการทำ Brute Force ได้หลายรูปแบบได้แก่

- HTTP (Basic Authentication)
- HTTP (HTML Form/CGI)
- POOP3 (Post Office Protocol v3)
- FTP (File Transfer Protocol)
- SMB (Server Message Block)

ตัวอย่างโปรแกรมดังรูปที่ 6.3



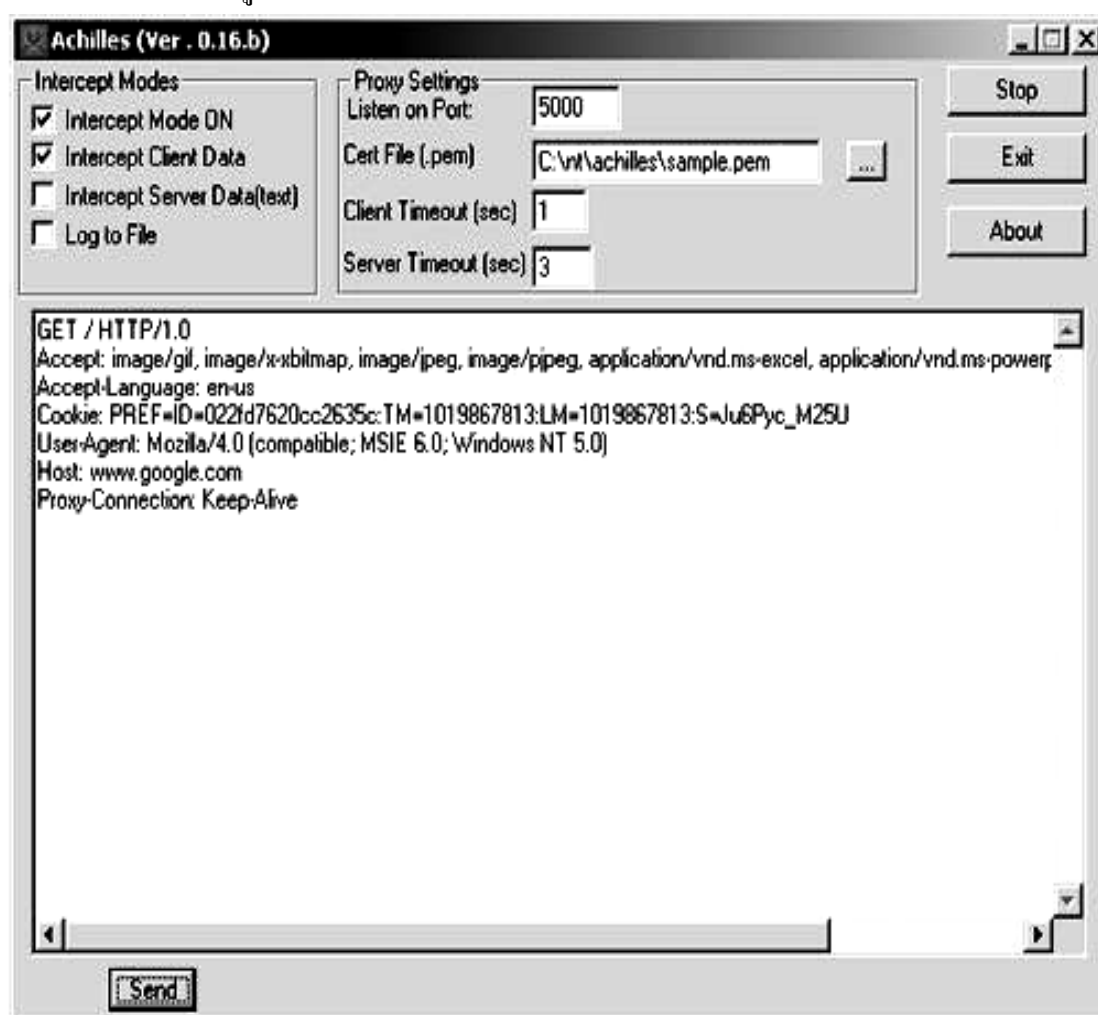
รูปที่ 6.3 โปรแกรม Brutus

6.4 Achilles

Achilles เป็นหนึ่งในเครื่องมือแฮกเว็บที่ไม่ค่อยมีเสถียรภาพเท่าใดแต่ทรงประสิทธิภาพโดดเด่นสำหรับวินโดวส์มันทำงานคล้ายเป็น Web proxy ด้วยการดักจับข้อมูลที่ถูกส่งกลับไปให้เว็บเซิร์ฟเวอร์และจากนั้นก็เปิดโอกาสให้ผู้ใช้ได้แก้ไขข้อมูลก่อนและค่อยส่งมันไปให้เซิร์ฟเวอร์ Achilles ประกอบด้วยฟีเจอร์ต่อไปนี้

- Proxy server (สามารถเปลี่ยนพอร์ตได้)
- การดักจับข้อมูลของ HTTP และ SSL
- การเพิ่มและการแก้ไขข้อมูลในเซสชันของ HTTP
- การคำนวณใหม่ของฟิวด์ HTTP ที่ต้องการ
- การทดสอบบัฟเฟอร์โอเวอร์โฟลว์
- การเก็บบันทึกสื่อของเซสชัน HTTP และ SSL

ตัวอย่างโปรแกรมดังรูปที่ 6.4



รูปที่ 6.4 โปรแกรม Achilles

6.5 Cookie Pal

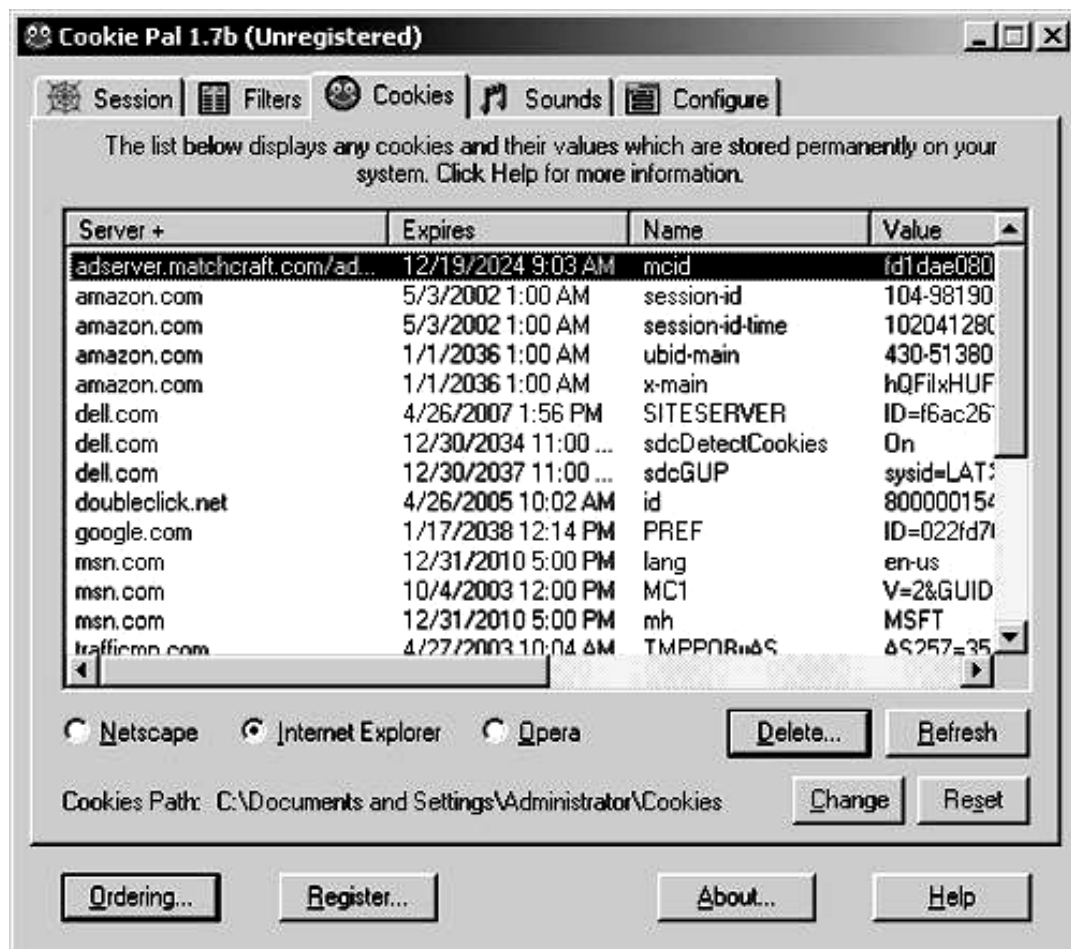
Cookie Pal เป็นหนึ่งในโปรแกรมที่ดีมากสำหรับการมอนิเตอร์การเพิ่มและแก้ไข cookie Cookie เป็นฟิลด์ของข้อมูลที่ถูกสร้างเก็บไว้ในหนึ่งไฟล์หรือหลายๆ ไฟล์ซึ่งเบราว์เซอร์ใช้เก็บรักษาสถานะและข้อมูลบางอย่างโดยทั่วไป cookie จะถูกซ่อนไม่ให้ผู้ใช้มองเห็น และถือว่าไม่มีอันตรายอะไร อย่างไรก็ตาม cookie สามารถถูกใช้เพื่อหลอกให้เว็บเซิร์ฟเวอร์ส่งข้อมูลที่มากเกินไปจนเกินกว่าความจำเป็นมาให้ กล่าวอีกอย่างหนึ่งว่า เราสามารถแก้ไขสิ่งที่ใช้ยืนยันตัวตนของเราต่อเซิร์ฟเวอร์ด้วยการแก้ไขค่าของ cookie ได้และค่อยส่งมันกลับไปใหม่ยังเว็บเซิร์ฟเวอร์ผ่านทาง GET request

Cookie มีสองประเภทถูกใช้โดยเซิร์ฟเวอร์และเบราว์เซอร์ นั่นคือประเภท Session (ชั่วคราว) และ persistent (ถาวร) Cookie ประเภทชั่วคราว หรือ Session cookie จะถูกเก็บอยู่ในหน่วยความจำและเป็นฟิลด์ข้อมูลชั่วคราวซึ่งถูกเก็บไว้จนกว่าเบราว์เซอร์จะถูกปิดลงไป ส่วน Cookie ประเภทถาวร หรือ persistent cookie นั้นจะถูกเขียนเก็บลงในฮาร์ดดิสก์และเบราว์เซอร์จะเข้ามาอ่านมันเมื่อต้องการ

ตัวอย่างโปรแกรมดังรูปที่ 6.5



รูปที่ 6.5 โปรแกรมCookie Pal Alert



รูปที่ 6.6 หน้าจอของ Cookie Pal

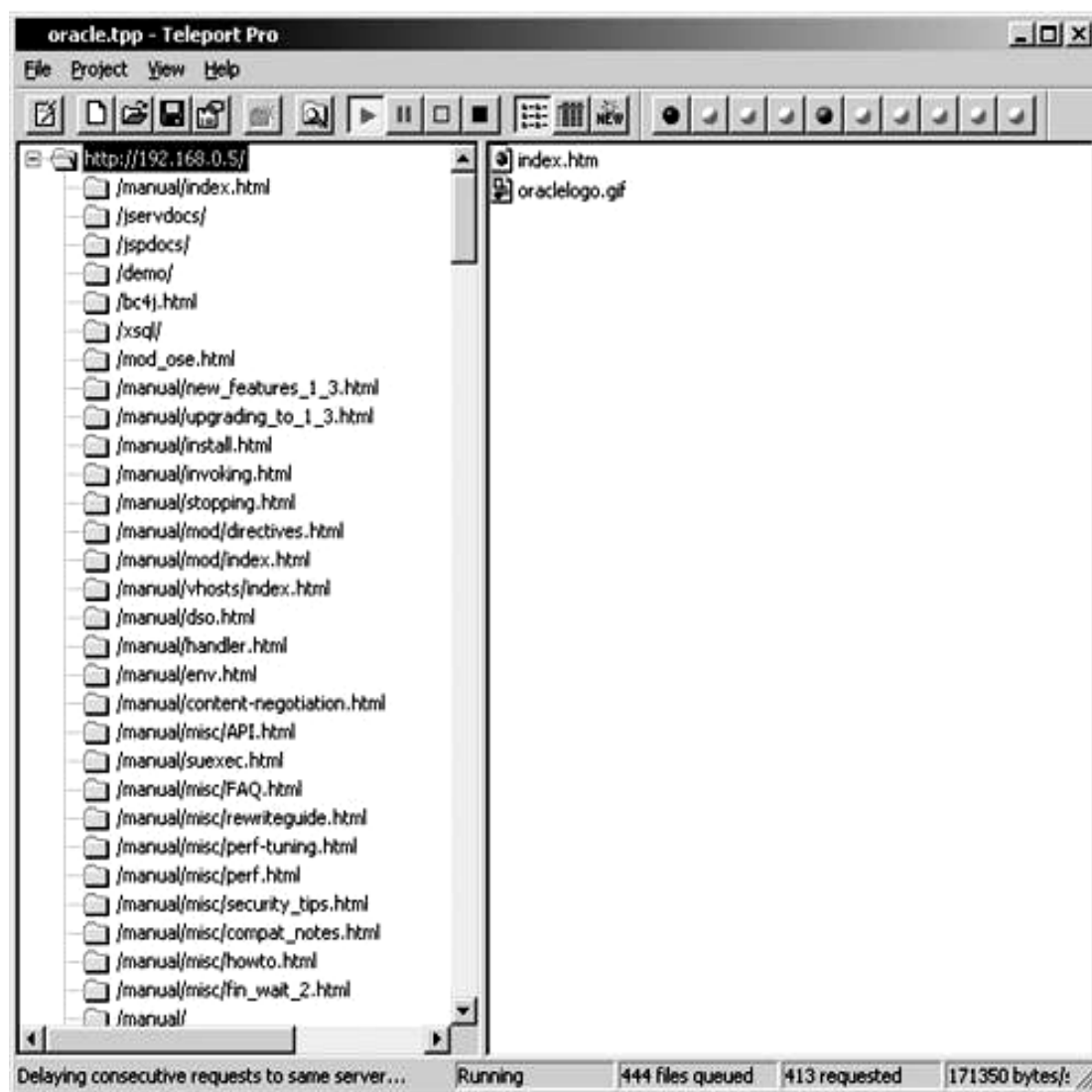
6.6 Teleport Pro

Teleport Pro เป็นหนึ่งในเครื่องมือคัดลอกเว็บไซต์สำหรับวินโดวส์ที่ดีที่สุด มันมีชื่อเสียงด้านความแข็งแกร่งและการทำงานที่รวดเร็ว มันสามารถดึงเอา URL และเรียกเอาไฟล์ทั้งหมดและไฟล์ที่เกี่ยวข้องกับเว็บเซิร์ฟเวอร์ในลักษณะแบบมัลติเซด เครื่องมือนี้ใช้งานง่ายและสามารถสำเนาเอาคอนเทนต์ทั้งหมดของเว็บไซต์ทั้งหมดของเว็บไซต์มาไว้ที่เครื่องคอมพิวเตอร์ของคุณได้

คอนเทนต์ของเว็บไซต์ที่ถูกมิเรอร์มา สามารถเข้ามานั่งไล่อ่านซอร์ซโค้ด โดยเฉพาะโค้ดที่ถูกส่งมารันที่ไคลเอนต์ได้เพื่อค้นหาช่องโหว่ที่อาจมีอยู่และหาข้อมูลสำคัญต่อไปนี้

- คอมเมนต์ที่ไม่เหมาะสม
- การแยกแยะหา Form ที่มีอยู่
- การแยกแยะหา Script

ตัวอย่างโปรแกรมดังรูปที่ 6.7



รูปที่ 6.7 โปรแกรม Teleport Pro